

Office of the Governor

Governor's Office of Information Technology

RULES IN SUPPORT OF THE COLORADO INFORMATION SECURITY ACT

8 CCR 1501-5

[Editor's Notes follow the text of the rules at the end of this CCR Document.]

5.1 Authority

The Chief Information Security Officer in the Office of Information Technology (OIT) is authorized and directed by the provisions of sections 24-37.5-403(2)(b), C.R.S., 24-37.5-403(2)(i), C.R.S., 24-37.5-404(1), C.R.S., 24-37.5-404.5(3)(a), C.R.S. and the Information Security Act, Title 24, Article 37.5, Part 4, C.R.S. to promulgate rules to ensure the development and maintenance of minimum information security controls to protect communication and information resources that support the operations and assets of public agencies.

The rules are intended to be consistent with the requirements of the State Administrative Procedures Act, section 24-4-101 et seq., C.R.S. (the "APA").

5.2 Scope and Purpose

- A. The primary goal of these rules is to provide for the safety and security of communication and information resources within the State.
- B. These rules govern the development and maintenance of minimum information security controls to protect public agency assets against unauthorized access, disclosure, use, and modification or destruction, whether accidental or deliberate, as well as to assure the confidentiality, integrity, and availability of information.

5.3 Applicability

- A. These rules apply to all public agencies as defined in C.R.S. section 24-37.5-102(26), that manage and administer IT systems intended to store, process, or transmit data.
- B. These rules do not apply to state-supported institutions of higher education or the general assembly in accordance with C.R.S. section 24-37.5-102(26).

5.4 Definitions

Agency Cybersecurity Plan (ACSP): An information security plan created and implemented by the information security personnel assigned to non-consolidated agencies on an annual basis that describes the Agency's current security posture,

includes an assessment of current risk, covers the incident response capabilities, disaster recovery capabilities, and a plan of action and milestones that describe current gaps in the security program and summarizes the goals of the Agency to address those gaps over the coming fiscal year.

Agency Designated Information Security Officer: A role delegated to a knowledgeable individual, responsible for supporting the Agency Cybersecurity Plan.

Chief Information Security Officer (CISO): Unless otherwise referenced, CISO refers to the CISO as established by C.R.S. § 24-37.5-403.

Enterprise Cybersecurity Plan (ECSP): An annual information security plan created by the Office of Information Security within OIT for State Agencies. The ECSP includes an assessment of current risk, covers incident response and disaster recovery capabilities, and includes a plan of action and milestones that describe current gaps in the security program and summarize the goals of OIT to address those gaps over the coming fiscal year.

Incident: An unplanned interruption to or quality reduction of an IT service.

Non-Consolidated Agency or Agencies: Those public agencies whose information technology functions were not consolidated within the Governor's Office of Information Technology and are not defined as a state agency under C.R.S. § 24-37.5-102(28).

Plan of Action and Milestones (POA&M): Agency remediation plans to close compliance gaps and mitigate known risks.

Public Agency: Has the same meaning as defined in C.R.S. § 24-37.5-102(26), which means every state office, whether executive or judicial, and all of its respective offices, departments, divisions, commissions, boards, bureaus, and institutions. "Public Agency" does not include institutions of higher education or the general assembly.

Risk: The possibility of harm or loss to any software, information, hardware, administrative, physical, communications or personnel resource.

Security Incident: Has the same meaning as defined in C.R.S. § 24-37.5-102(27), which means an accidental or deliberate event that results in or constitutes an imminent threat of the unauthorized access, loss, disclosure, modification, disruption, or destruction of communication and information resources.

State Agency: Has the same meaning as defined in C.R.S. § 24-37.5-102(28), which means all of the departments, divisions, commissions, boards, bureaus, and institutions in the executive branch of the state government. "State Agency" does not include the legislative or judicial department, the department of education, the department of law, the department of state, the department of the treasury, or state-supported institutions of higher education. Colorado SB 08-155 consolidated the IT functions of State Agencies under OIT.

State Chief Information Officer (CIO): Has the same meaning as defined in C.R.S. § 24-37.5-102(3), which means the chief information officer appointed pursuant to § 24-37.5-103, C.R.S.

5.5 Information Security Planning

- A. Information security planning is essential to prevent unauthorized access, disclosure, duplication, modification, diversion, destruction, loss, misuse or theft of electronic and non-electronic information assets.
- B. Each public agency in the State of Colorado shall maintain and implement an ACSP or ECSP to control risks associated with access, use, storage and sharing of citizen and State electronic and non-electronic information.
 - 1. Duties of Non-Consolidated Agencies:
 - a. Designate an individual with agency IT knowledge as an Agency Designated Information Security Officer. The individual should exhibit a background and expertise in security and risk management for communications and information resources.
 - b. The Agency Designated Information Security Officer and appropriate support staff shall develop, maintain, and implement an ACSP.
 - 2. State agencies under C.R.S. § 24-37.5-102(28) are included in the ECSP managed by OIT. The State CISO shall be responsible for carrying out the ECSP, and may delegate activities related to the ECSP to appropriate experienced and knowledgeable OIT staff.
 - 3. Duties of State Agencies:
 - a. Follow the ECSP and activities associated with the ECSP in collaboration with the State CISO and other OIT staff.
- C. Duties of Institutions of Higher Education:
 - 1. Submit a report concerning the development and implementation of the institution's information security program and compliance to the Department of Higher Education according to the specifications of C.R.S. § 24-37.5-404.5.

5.6 Cybersecurity Plan Submission

- A. ACSPs and ECSPs are due annually, on or before July 15 of each year.
 - 1. Each non-consolidated agency shall submit their ACSP to the State CISO for review and approval.

- a. The State CISO or delegated OIT staff with appropriate experience and knowledge are available on request to consult with and support agencies with completing the ACSP.
 2. The Department of Higher Education shall submit the information security program and compliance reports from institutions of higher education to the State CISO according to the provisions of C.R.S. § 24-37.5-404.5.
 3. The State CISO shall submit the ECSP to the State CIO for review and approval.
- B. An ACSP or an ECSP shall include the following sections, at a minimum:
1. Cover letter.
 2. OIT Cybersecurity Review Template or information security review based on the most recent version of the National Institute of Standards and Technology (NIST) Cybersecurity Framework (CSF), available at www.nist.gov/cyberframework.
 3. Plan of Action and Milestones (POA&M) related to prioritized items from the completed Cybersecurity Review Template, identified risks, and any other security priorities identified by the agency.
 4. Documents numbered 2 through 3, above, are not public records subject to disclosure through the Colorado Open Records Act pursuant to Sections 24-72-202(6)(b)(X), C.R.S. and 24-72-202(6)(b)(XII), C.R.S. Each such document and any supporting materials shall be labeled "Confidential" and "Not a Public Record."
- C. The State CISO or designee shall meet with the agency to discuss the ACSP, vulnerabilities, and priorities for action.
- D. The State CISO shall meet with the Department of Higher Education to discuss all reports concerning the development and implementation of information security programs and compliance with § 24-37.5-404.5, C.R.S. that have been received by the Department of Higher Education for that year.
- E. The State CISO shall review and approve, conditionally approve, or disapprove each ACSP based on evaluation of the documentation and discussion with the Agency Designated Information Security Officer.
1. On or before September 15, the State CISO shall send a notice of approval, conditional approval, or disapproval to the Agency Designated Information Security Officer.
 - a. An approval notice shall confirm the agency's compliance with the requirements of the cybersecurity plans.

- b. A conditional approval notice shall specify the areas of concern and corrective action to address the issue. A conditional approval notice shall also be sent to the head of the agency.
 - c. A disapproval notice shall specify the reason for the disapproval and corrective action to address the issue. A disapproval notice shall also be sent to the head of the agency, the Governor and the State CIO.
 - d. A notice of failure to submit shall describe the attempts to acquire an ACSP from the agency. A notice of failure to submit shall also be sent to the head of the agency, the Governor and the State CIO.
- 2. ACSP disapproval may occur but is not limited to the following instances:
 - a. Failure to submit an ACSP to the State CISO by July 15.
 - b. Failure to meet and discuss the ACSP with the State CISO or designee.
- 3. The State CISO may delegate review and evaluation activities to appropriate experienced and knowledgeable OIT staff. The final decision to approve or disapprove each ACSP may not be delegated.

5.7 Exceptions or Extensions

- A. In exceptional circumstances, an agency may request a temporary exception to these rules or a deadline extension if it can demonstrate that compliance would result in undue hardship or significant operational challenges. Exception or extension requests must be submitted in writing through the agency's IT Director to the State CISO, explaining the circumstances necessitating the exception or extension and a timeline for achieving compliance with the rules.
- B. The State CISO or delegate will review exception or extension requests on a case-by-case basis and may grant exceptions or extensions if they are deemed necessary and appropriate. Granted exceptions or extensions may be temporary or subject to specific conditions or limitations, and will be reviewed periodically to ensure they remain justified and aligned with the overall goals of the rules.

5.8 Materials Incorporated by Reference

- A. The National Institute of Standards and Technology (NIST) Cybersecurity Framework (CSF), available at www.nist.gov/cyberframework, in effect as of February 26, 2024, is hereby incorporated into 8 CCR 1501-5, Rules in Support of the Colorado Information Security Act by reference pursuant to C.R.S. §24-4-103(12.5), and does not include any later amendments.

- B. The NIST CSF incorporated by reference into these rules is available at no cost in an electronic form online at www.nist.gov/cyberframework.
- C. The Colorado Governor's Office of Information Technology also maintains a copy of the policies, rules, and standards incorporated by reference into these rules, which is available from the office during regular business hours.

5.9 Severability

If any provision of these Rules in Support of the Colorado Information Security Act, 8 CCR 1501-5, is found to be invalid by a court of competent jurisdiction, the remaining provisions of these rules shall remain in full force and effect.

Editor's Notes

History

Entire rule eff. 12/30/2013.

Entire rule eff. 06/30/2026.